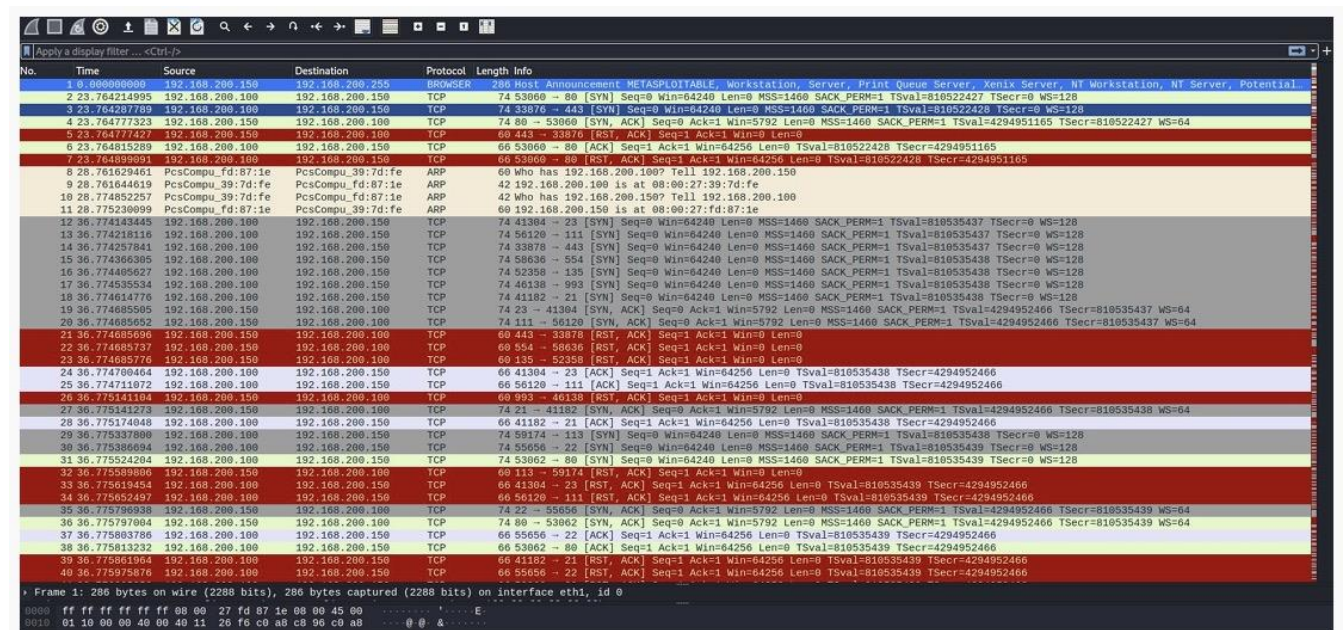


Analisi di log su Wireshark

Nell'esercizio di oggi analizzeremo un'istanza di traffico su Wireshark e cercheremo di capire se si tratti di traffico legittimo o se ci siano indicatori di compromissione (IOC).



No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000000	192.168.200.150	192.168.200.255	BROADCAST	288	Host Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Xenix Server, NT Workstation, NT Server, Potential
2	23.764214995	192.168.200.100	192.168.200.150	TCP	74	53060 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810522427 TSecr=0 WS=128
3	23.764277759	192.168.200.100	192.168.200.150	TCP	74	53076 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810522428 TSecr=0 WS=128
4	23.764777323	192.168.200.150	192.168.200.100	TCP	74	80 → 53060 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294951169 TSecr=810522427 WS=64
5	23.764777427	192.168.200.150	192.168.200.100	TCP	66	443 → 33876 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
6	23.764815289	192.168.200.100	192.168.200.150	TCP	66	53060 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
7	23.764895951	192.168.200.100	192.168.200.150	TCP	66	53060 → 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
8	28.761829461	PcsCompu...fd:87:1e	PcsCompu...39:7d:fe	ARP	60	Who has 192.168.200.100? Tell 192.168.200.150
9	28.761844619	PcsCompu...39:7d:fe	PcsCompu...fd:87:1e	ARP	42	192.168.200.100 is at 08:00:27:39:7d:fe
10	28.774852257	PcsCompu...39:7d:fe	PcsCompu...fd:87:1e	ARP	42	Who has 192.168.200.150? Tell 192.168.200.100
11	28.775239999	PcsCompu...fd:87:1e	PcsCompu...39:7d:fe	ARP	60	192.168.200.150 is at 08:00:27:fd:87:1e
12	36.774134445	192.168.200.100	192.168.200.150	TCP	74	41384 → 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535437 TSecr=0 WS=128
13	36.774218115	192.168.200.100	192.168.200.150	TCP	74	56120 → 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535437 TSecr=0 WS=128
14	36.774257841	192.168.200.100	192.168.200.150	TCP	74	33876 → 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535437 TSecr=0 WS=128
15	36.774366305	192.168.200.100	192.168.200.150	TCP	74	56836 → 554 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535438 TSecr=0 WS=128
16	36.774485627	192.168.200.100	192.168.200.150	TCP	74	52358 → 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535438 TSecr=0 WS=128
17	36.774535534	192.168.200.100	192.168.200.150	TCP	74	46138 → 993 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535438 TSecr=0 WS=128
18	36.774614776	192.168.200.100	192.168.200.150	TCP	74	41182 → 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535438 TSecr=0 WS=128
19	36.774685505	192.168.200.150	192.168.200.100	TCP	74	23 → 41384 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535437 WS=64
20	36.774685652	192.168.200.150	192.168.200.100	TCP	74	111 → 56120 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535437 WS=64
21	36.774685696	192.168.200.150	192.168.200.100	TCP	66	443 → 33876 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
22	36.774685737	192.168.200.150	192.168.200.100	TCP	66	554 → 56836 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
23	36.774685776	192.168.200.150	192.168.200.100	TCP	66	135 → 52358 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
24	36.774700464	192.168.200.100	192.168.200.150	TCP	66	41384 → 23 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
25	36.774711072	192.168.200.100	192.168.200.150	TCP	66	56120 → 111 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
26	36.775141104	192.168.200.150	192.168.200.100	TCP	66	135 → 52358 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
27	36.775141273	192.168.200.150	192.168.200.100	TCP	74	21 → 41182 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535438 WS=64
28	36.775174048	192.168.200.100	192.168.200.150	TCP	66	41182 → 21 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
29	36.775378800	192.168.200.100	192.168.200.150	TCP	74	59174 → 113 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535438 TSecr=0 WS=128
30	36.775385684	192.168.200.100	192.168.200.150	TCP	74	55656 → 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535439 TSecr=0 WS=128
31	36.775524264	192.168.200.100	192.168.200.150	TCP	74	53062 → 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535439 TSecr=0 WS=128
32	36.775589806	192.168.200.150	192.168.200.100	TCP	66	113 → 59174 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
33	36.775619454	192.168.200.100	192.168.200.150	TCP	66	41384 → 23 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
34	36.775652497	192.168.200.100	192.168.200.150	TCP	66	56120 → 111 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
35	36.775709938	192.168.200.150	192.168.200.100	TCP	74	22 → 55656 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535439 WS=64
36	36.775737804	192.168.200.150	192.168.200.100	TCP	74	80 → 53062 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535439 WS=64
37	36.775803786	192.168.200.100	192.168.200.150	TCP	66	55656 → 22 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
38	36.775813232	192.168.200.100	192.168.200.150	TCP	66	53062 → 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
39	36.775861954	192.168.200.100	192.168.200.150	TCP	66	41182 → 21 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
40	36.775973876	192.168.200.100	192.168.200.150	TCP	66	55656 → 22 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466

Prime impressioni

Da questo primo screenshot possiamo vedere come, in cima, il primo pacchetto mostra una macchina .150 che comunica verso il broadcast, quindi a tutte le macchine sulla sua rete, chi è e che cosa fa. Questo è già un problema, perché una macchina sicura dovrebbe essere silenziosa, non annunciarsi a tutte le macchine sulla rete. Comunque sia, come avremo conferma dopo, la macchina .150 è una metasploitable, ed è la vittima in questo scenario.

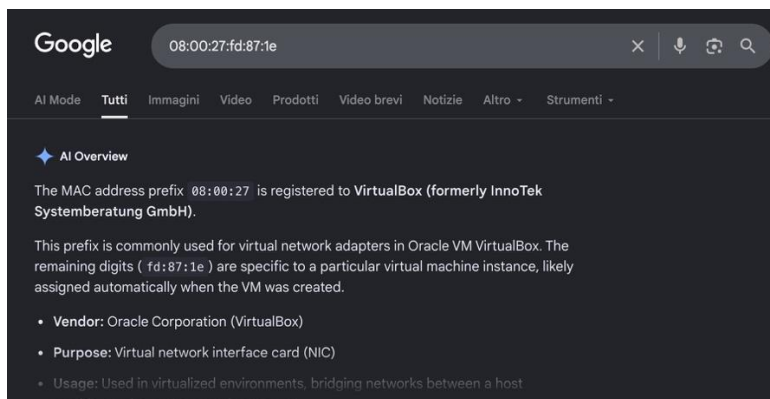
L'attaccante

Vediamo entrare in gioco anche una macchina .100 che inizia ad inviare pacchetti TCP alla macchina vittima. La length durante tutta la cattura di rete non oltrepassa mai il valore 74, il che ci rassicura già che non ci siano stati scambi di dati importanti, ma solo comunicazioni “di conoscenza” tra le due macchine.

Un altro curioso parametro è quello del tempo. Questi pacchetti vengono inviati freneticamente da una macchina all'altra nel giro di pochi secondi. Forse l'attaccante sta usando un tool automatizzato.

ARP: un interessante indizio

Dal pacchetto 8 al pacchetto 11 c'è una comunicazione ARP, ossia address resolution protocol. La macchina vittima, per rispondere all'attaccante, deve sapere dove mandare i pacchetti di risposta. Qui troviamo un indizio molto interessante. Infatti, l'ARP cerca di risolvere i primi tre byte del MAC address dell'attaccante, e nel pacchetto 11 ci dice chiaramente che l'IP .100 si trova al MAC address 08:00:27:fd:87:1e. Proviamo a cercare questo indirizzo.



Abbiamo un tassello importante del puzzle, si tratta di una simulazione in laboratorio, in cui una macchina virtuale che gira su VirtualBox sta cercando di mettersi in comunicazione con una Metasploitable.

Ricerca di IOC

Vediamo nel concreto però cosa succede. Vediamo in questo screenshot, ma anche negli altri non è diverso, come l'attaccante stia cercando di instaurare un three-handshake (SYN, SYN-ACK, ACK), ma come vediamo in rosso abbiamo sempre la risposta di RST che indica un'interruzione brusca di comunicazione.

Nella colonna info vediamo i numeri delle porte che l'attaccante sta interrogando.

Dai pacchetti con [ACK] possiamo vedere quali porte abbiano risposto all'attaccante. Vediamo le porte:

23, 111, 21, 22, 80, 445, 25, 53, 139, 445 e 512.

Questa è una miniera d'oro per un attaccante. Ogni porta aperta rappresenta una superficie d'attacco, o meglio una via per entrare. Vi sentireste sicuri a dormire in una casa con undici finestre spalancate?

No.	Time	Source	Destination	Protocol	Length	Info
40	36.775975876	192.168.200.100	192.168.200.150	TCP	60	53666 → 22 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
41	36.776005853	192.168.200.100	192.168.200.150	TCP	66	53862 → 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
42	36.776179338	192.168.200.100	192.168.200.150	TCP	74	50604 → 199 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535439 TSecr=0 WS=128
43	36.776233880	192.168.200.100	192.168.200.150	TCP	74	54220 → 995 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535439 TSecr=0 WS=128
44	36.776336618	192.168.200.100	192.168.200.150	TCP	74	34648 → 587 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535440 TSecr=0 WS=128
45	36.776395694	192.168.200.100	192.168.200.150	TCP	74	33842 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535440 TSecr=0 WS=128
46	36.776402500	192.168.200.100	192.168.200.150	TCP	74	48814 → 256 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535440 TSecr=0 WS=128
47	36.776451284	192.168.200.150	192.168.200.100	TCP	60	199 → 50684 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
48	36.776451357	192.168.200.150	192.168.200.100	TCP	60	995 → 54220 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
49	36.776476291	192.168.200.100	192.168.200.150	TCP	74	6699 → 139 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535440 TSecr=0 WS=128
50	36.776496366	192.168.200.100	192.168.200.150	TCP	74	33296 → 143 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535440 TSecr=0 WS=128
51	36.776512221	192.168.200.100	192.168.200.150	TCP	74	60632 → 25 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535440 TSecr=0 WS=128
52	36.776568606	192.168.200.100	192.168.200.150	TCP	74	49654 → 110 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535440 TSecr=0 WS=128
53	36.776671271	192.168.200.100	192.168.200.150	TCP	74	37282 → 53 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535440 TSecr=0 WS=128
54	36.776720715	192.168.200.100	192.168.200.150	TCP	74	54898 → 500 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535440 TSecr=0 WS=128
55	36.776813123	192.168.200.150	192.168.200.100	TCP	60	587 → 34648 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
56	36.776843423	192.168.200.150	192.168.200.100	TCP	74	51534 → 487 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535440 TSecr=0 WS=128
57	36.776904928	192.168.200.150	192.168.200.100	TCP	74	445 → 33842 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535440 WS=64
58	36.776949322	192.168.200.150	192.168.200.100	TCP	60	256 → 48814 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
59	36.776984961	192.168.200.150	192.168.200.100	TCP	74	139 → 46990 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535440 WS=64
60	36.776995904	192.168.200.150	192.168.200.100	TCP	60	143 → 33296 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
61	36.776995843	192.168.200.150	192.168.200.100	TCP	74	25 → 60632 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535440 WS=64
62	36.776995002	192.168.200.150	192.168.200.100	TCP	60	110 → 49654 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
63	36.776995123	192.168.200.150	192.168.200.100	TCP	74	53 → 37282 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM=1 TSval=4294952466 TSecr=810535440 WS=64
64	36.776995162	192.168.200.150	192.168.200.100	TCP	60	500 → 54898 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
65	36.776914772	192.168.200.100	192.168.200.150	TCP	66	33042 → 445 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
66	36.776941020	192.168.200.100	192.168.200.150	TCP	66	46990 → 139 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
67	36.776962320	192.168.200.100	192.168.200.150	TCP	66	60632 → 25 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
68	36.776983878	192.168.200.100	192.168.200.150	TCP	66	37282 → 53 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535440 TSecr=4294952466
69	36.777118481	192.168.200.150	192.168.200.100	TCP	60	487 → 51534 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
70	36.777143814	192.168.200.100	192.168.200.150	TCP	74	56990 → 787 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535440 TSecr=0 WS=128
71	36.777186821	192.168.200.100	192.168.200.150	TCP	74	35638 → 430 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535440 TSecr=0 WS=128
72	36.777302991	192.168.200.100	192.168.200.150	TCP	74	34120 → 98 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535441 TSecr=0 WS=128
73	36.777337934	192.168.200.100	192.168.200.150	TCP	74	49780 → 78 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535441 TSecr=0 WS=128
74	36.777438632	192.168.200.150	192.168.200.100	TCP	60	787 → 56990 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
75	36.777439741	192.168.200.150	192.168.200.100	TCP	60	430 → 35638 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
76	36.777473018	192.168.200.100	192.168.200.150	TCP	74	36138 → 580 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535441 TSecr=0 WS=128
77	36.777522494	192.168.200.100	192.168.200.150	TCP	74	52428 → 962 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM=1 TSval=810535441 TSecr=0 WS=128
78	36.777623082	192.168.200.150	192.168.200.100	TCP	60	98 → 34120 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
79	36.777623149	192.168.200.150	192.168.200.100	TCP	60	78 → 49780 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0

Dopodiché, come possiamo vedere nei pacchetti 40 e 41, è l'attaccante a chiudere bruscamente la comunicazione con la porta 22 e 80, tipico segno di un tool che non fa altro che chiedere “Questa porta è aperta?” e se la risposta è “Sì!”, interrompe la comunicazione. Probabilmente si tratta di uno stealth scan con Nmap.

Conclusioni

Ormai non ci sono dubbi: siamo di fronte ad una fase di enumerazione con un tool automatizzato, con tutta probabilità Nmap, da parte di una macchina virtuale che gira su VirtualBox, ai danni di una macchina vulnerabile Metasploitable.

Dunque, ci troviamo in una situazione di laboratorio senza alcun indicatore di compromissione vero.

La conferma che si tratti solo di enumerazione ce lo dà il fatto che il protocollo del pacchetto sia sempre TCP e che la *length* non superi mai il 74, chiaro segno di una comunicazione “conoscitiva” tra le due macchine, non ci sono stati scambi di dati importanti

E se invece...?

Cosa avremmo potuto notare invece se si fosse trattato di un attacco riuscito? Innanzitutto, vedremmo la *length* sbalzare a livelli molto più alti.

Ipotizzando che l'attaccante si focalizzi sulle porte 80 e 22, vedremmo, nel primo caso nella colonna *protocol* la scritta HTTP, vedremmo non più richieste di handshake ma richieste di GET, POST, che avrebbero potuto segnalare tentativi di **SQL injection**. Nel secondo caso, avremmo potuto vedere centinaia se non migliaia di tentativi di connessione verso la porta 22, indicatore di un tentativo di Brute-forcing con tool come Hydra.

Consigli Blue Team

In finale, da questi log si evince che un attaccante sta eseguendo una scansione porte sulla macchina .150. Non abbiamo motivo di pensare che ci sia già stata compromissione o fuga di data.

Tuttavia, undici porte aperte sono inaccettabili per la sicurezza di una rete, ciò che rappresenta è una via d'ingresso spianata, soprattutto perché tra queste ci sono la 23(Telnet) e la 21(FTP), che trasmettono dati in chiaro.

La situazione non è critica al momento ma potrebbe presto precipitare se non agiamo.

Per prima cosa blocchiamo l'indirizzo IP attaccante. Abbiamo due opzioni, che non si autoescludono:

1. Su firewall perimetrale: una regola di blocco sul firewall che impedisca alla Metaspitable di ricevere qualsiasi richiesta proveniente da quell'IP, azione consigliata.
2. Sulla macchina vittima: con il comando

```
iptables -A INPUT -s 192.168.200.100 -j DROP
```

La macchina vittima smetterebbe di rispondere, ignorando completamente l'attaccante, probabilmente più rapida nel caso stesso assistendo in tempo reale alla ricognizione offensiva.

Consigli Red Team

L'Attaccante sta di sicuro usando il tool Nmap per scansionare le porte, ma lo sta usando in modo troppo rumoroso. Guardando i log, anche una persona non del mestiere intuirebbe che c'è qualcosa che non va, data l'enorme quantità di pacchetti rossi. Questo perché l'attaccante sta mandando centinaia di richieste ad intervalli di circa trenta secondi l'una dall'altra.

Due piccoli accorgimenti avrebbero potuto rendere il lavoro del SOC molto più difficile.

Una delle sfide più impegnative per il SOC è l'enorme quantità di dati che deve essere analizzata ogni giorno, come cercare un ago in un pagliaio. L'attaccante, quindi, può approfittare di questo e nascondersi tra tanto "rumore", settando il parametro -t a 0 (paranoid) che invia un pacchetto ogni cinque minuti. Quello che avremmo visto nei log, invece di tantissime righe rosse tutte insieme, sarebbe stato una riga rossa ogni cinque minuti, il che ci avrebbe fatto insospettire di meno probabilmente.

Un'altra tecnica è quella dell'uso della modalità *Decoy* (-D) di Nmap che invia il pacchetto non solo dall'indirizzo IP dell'attaccante ma contemporaneamente lo invia più e più volte da indirizzi IP esca. Ci troveremmo a dover bloccare molteplici indirizzi IP, rischiando oltretutto di bloccare di innocui, che porterebbero interruzioni di servizio.